INDEPENDENT REVIEW PAPER · VERSION 0.9 FOR COMMUNITY REVIEW

ResonantOS and ResonantDAO: an independent review

What works, where the code and the documents disagree, and a path that needs no rewrite

Bartolomeo · 22 October 2026 · Research carried out 20–22 October 2026

How to read this paper. The projects belong to their community, and their maintainers know them far better than we do. Everything here is a finding to check, not a verdict. Each claim rests on a file, line or page recorded in the full report; where we are wrong, we would like to know, and later versions of this paper will list every correction. This is technical research, not legal or investment advice.

Abstract

We studied ResonantOS, an AI-assisted browser environment, and ResonantDAO, its planned contribution-based community organisation, by reading their code and public documents at fixed versions. We then searched about 36 code platforms and research indexes in seven languages for existing open-source work that could meet the projects' needs, found 586 relevant projects, and inspected 16 of them closely at pinned commits. Nothing was installed or run. The ResonantOS 2.0.0 Alpha is a real, working product with 114 permission-protected actions and 2,424 passing automated tests; it is a base to build on. Several capabilities its documents describe as finished do not yet work as described. Across the inspected projects the same three design errors recurred, and we recommend settling them once for the whole system: one protected store for security records, an approval step the AI cannot operate, and a key-holding broker so AI helpers never see provider API keys. ResonantDAO exists as a specification only; we recommend an off-chain first phase with a witnessed public record, signed membership records and recountable advisory votes, and no token until an audit, a custody policy and a test-network trial exist. We close with what can be borrowed, four notes for the maintainers, our limits, and first tasks for contributors.

1. Key findings

- **The Alpha works.** A Chrome extension plus a local service (the "bridge"), with 114 actions each behind its own permission, deny-by-default for anything undeclared, 2,424 automated tests passing on the commit studied, and a nightly test that drives a real Chrome.
- **Seven claims run ahead of the code.** Knowledge promotion cannot run; per-site permissions are enforced only in the side panel; "signed" add-ons carry no signature; human-only rules match English text; helper isolation exists on macOS only; seven local bridge addresses need no password; the status page is about 190 commits behind.
- **Three recurring design errors.** When we sketched how each inspected project would plug into ResonantOS, our adversarial reviewers found the same mistakes again and again: security records placed where the adversary can write (ten placements in nine of fifteen designs), approvals ending where the AI's own context can reach (seven designs in six), and provider keys reaching the helper programs, as they do in the Alpha today.
- **An honest limit.** On Windows today every AI helper runs as the user, unconfined. Until the security core runs under its own account (six to twelve months out), the interface should say so plainly.
- **No rewrite.** Every recommended step is a normal-sized change that keeps the existing tests passing.

- **The DAO should start off-chain.** There is no live code. A witnessed ledger, signed membership records and advisory votes need no token, contract, audit or custody arrangement.

2. Scope and method

2.1 What we read

Source	Identity	Accessed
ResonantOS 2.0.0-alpha	Commit 578fbbc (branch dev, 18 October 2026), its documents, and its CI results read through the GitHub API	20 Oct 2026
ResonantDAO	Whitepaper v0.6 (30 August 2026), Contribution Economy specification v2, membership portal, website	20 Oct 2026
Public test-network records	Solana devnet and mainnet reads of mints, program and upgrade authority, each reproduced by two independent agents	20–21 Oct 2026
Wider landscape	About 36 code platforms and research indexes in seven languages; 586 relevant projects; 185 candidate codebases on the longlist; 16 inspected at pinned commits	20–21 Oct 2026

Table 1. Sources. Pinned commits for the 16 inspected codebases are listed in the References.

2.2 How we checked ourselves

The research ran in four gated stages: a map of what exists, a multilingual discovery sweep, close inspection with adversarial reviewers (a security engineer, a code archaeologist and a DAO sceptic), and the written report. At each stage a fresh reviewer re-opened a sample of our pointers at the recorded commit. We publish our own error rates because readers should know how often we were wrong.

Stage	Sample re-checked	Result
1. Project map	15 of 63 capability claims	9 exact, 6 partial, 0 failed; all six corrected
2. Discovery	110 of 1,099 search records	7.5% error as scored (2.2% counting duplicates across agents as resolved); licence errors corrected
3. Inspection	189 decision-carrying citations in 16 reports	181 exact, 7 partial, 1 failed and fixed
4. Report	499 citations, plus one adversarial review	412 pass, 60 partial, 26 fail; every fail, partial, blocker and major issue corrected before release

Table 2. Verification by stage. Full detail in the evidence appendix, section G.

2.3 What the method cannot show

We ran nothing. Every “this works” rests on reading tests that already run in each project’s CI. Every property proposed here is *designed, not yet tested*, and the experiments that would test it are listed in section 10. On-chain facts were read on 20 and 21 October 2026 and can change.

3. ResonantOS today

3.1 What is working well

The Alpha is a working single-user product: a Chrome extension and a loopback Node service. Chat, page context, workspaces, browser control and memory intake all work and are covered by tests. Anything without a declared permission is refused by default, and the token plumbing between extension and bridge is careful. Every CI lane was green on the inspected commit. This is a solid base to build on, not something to replace.

3.2 Where the code and the documents disagree

None of the following is hidden. Mostly, the status pages have fallen behind the code.

#	Finding	What we saw
1	Knowledge promotion cannot run	Since commit 4098e28 (2 June 2026) the promote step always fails: caller and service pass information in different shapes, and the approval check reads a field the caller does not send. The capability list still says “Implemented”.
2	Per-site permissions are not enforced everywhere	Checked only in the side panel; “ask before acting” and “trusted” behave the same, and “blocked” does not stop navigation.
3	“Signed” add-ons carry no signature	Eight add-on manifests declare themselves signed; there are no signature bytes and no verifying code.
4	Human-only rules are text matching	Rules such as “only a human may publish or pay” look for English words on the page; a plain link with the right wording can pass.
5	Helper isolation on macOS only	On Linux and Windows, helpers such as Hermes and OpenCode run with the user’s full rights, and provider API keys are passed to them in their environment.
6	Seven bridge addresses need no password	Any program on the same computer can reach them.
7	Status page about 190 commits behind	It omits the vendored Augmentor app and the newer add-on harness; the Anthropic and Google provider presets have no code behind them yet.

Table 3. Capabilities described as finished that do not yet work as described.

4. Three recurring design errors, and the changes we recommend

The most useful result of the close inspection was not any single project but a pattern. For each inspected project we drafted how it would be integrated into ResonantOS, and independent adversarial reviewers then attacked those drafts. The same three mistakes appeared again and again in our own integration designs, and the first and third are also present in the Alpha today. Because they recur, we recommend settling each one once, as a decision for the whole system, rather than integration by integration.

4.1 One protected place for security records

Revocation lists, approval records, signing keys and “known-good version” markers should live in a single store outside the user’s own documents, written only by the bridge and unreachable by bridge routes and by confined helpers. Each record carries an integrity chain that reveals tampering or the restoration of an old copy. The reviewers found ten placements, across nine of the fifteen integration designs they read, that put such records in the user folder or the helper’s own configuration directory, where a single write by a helper could roll a revocation back.

4.2 An approval step the AI cannot operate

Important actions, such as promoting knowledge into the trusted wiki or starting a helper allowed to run commands, should wait for a small separate helper process that contains no agent code. It shows the person the exact action, records the answer in an append-only ledger, and only then lets the action run; if the record cannot be written, the action does not happen. There is no “approve” route on the bridge at all, so no token can approve anything. Seven approval designs, in six of the integration designs, had ended in a bridge route or extension prompt that the agent’s own context could call with a token it already held.

4.3 A key-holding broker

Helpers should never receive provider API keys; today the Alpha passes them to Hermes and OpenCode in their environment. A separate broker holds them, injects them into outgoing request headers and redacts them from anything that comes back. Redaction matters because some providers echo a request back, key included. This is also why we recommend Anthropic's sandbox-runtime for isolation only: its own key-masking mode returns the key to the child in exactly that echo case.

4.4 The honest limit

> On one user account these protections hold against other accounts, offline disk edits and properly isolated helpers. They do not hold against a program that runs as the user with no isolation. On Windows today, and anywhere the isolation switch is off, that describes every AI helper: it could operate its own approval window and read the keys. The gap closes only when the security core runs under its own account. Until then we recommend the interface says plainly on Windows: **"unconfined: this helper can approve its own actions"**.

5. The path we suggest for ResonantOS

We do not suggest a rewrite. The Alpha is hardened first; a small enforcement core is then extracted along named seams, so that the "neutral baseplate" the website describes comes to exist in code.

Phase	Work
Now (about four weeks)	Correct the status pages. Add the protected store. Add the key broker, plus Linux and macOS isolation behind a switch. Add the approval helper for promotion and for starting helpers, with the promotion fix in the same change. Require a password and a same-site check on the open bridge addresses.
Next (two to three months)	Per-helper permissions that expire and can be withdrawn mid-session. A signature check for add-ons, with revocation that suspends rather than uninstalls. Jobs that survive a crash without repeating an action that may already have happened. Content-aware choice between local and cloud models (5.1).
Later (six to twelve months)	Move the security core into its own small program, piece by piece. A supervisor that can restore a known-good version. Windows and macOS test runs in CI.

Table 4. Roadmap. Each step is a normal-sized pull request, and the existing tests keep passing.

5.1 A late addition: routing by content

On 21 October 2026, after the review was otherwise complete, Perplexity open-sourced PII-Tracer, a small local model that flags text that looks sensitive. ResonantOS currently chooses between local and cloud models on provider preference and speed alone; a page of private medical notes and a page of public news are routed the same way. We suggest adding the PII-Tracer flag as one input, shown to the person in the approval helper so that a person, not the AI, decides. It belongs in the Next phase because it depends on the approval helper and on working local models. A sibling release of the same model states that its sensitivity score is weak and needs calibration, so it is a signal to show, never a silent decision. This addition was not re-run through the citation checkers; its evidence is cited directly in the full report (threat T25).

6. ResonantDAO

6.1 A specification today

We found no official program, interface definition, program address or token mint in public. The membership portal describes itself as a design page, not yet live. From the whitepaper and the Contribution Economy specification we derived 62 requirements and registered 17 inconsistencies, among them rewards earned for activity against the stated principle of "outcome, never activity", three incompatible contribution ladders, and governance that is human-only while relying on a self-declared split between human and AI work. The official

texts do not yet cover vote delegation, emergency powers, key policy, revocation of credentials, key recovery or membership privacy.

6.2 Start off-chain

Element	Design
Public contribution record	Append-only, run with Tessera and countersigned by three outside witnesses under a 2-of-3 policy, with signed receipts for members.
Membership records	Signed, each carrying its reasons and an appeal route.
Advisory votes	Published so that anyone can recount them.

None of this needs a token, a smart contract, an audit or a custody arrangement. We recommend no token and no binding on-chain vote until an audit, a custody policy and a test-network trial of the exact program exist, and that whatever members accrue in this phase is described as a record of reviewed contribution, with no promise of later conversion. One residual risk should be stated openly: if one witness colludes with the log host, two groups of members could be shown different histories, and only members comparing what different witnesses signed would detect it.

6.3 Three related findings

Finding	Detail	Suggestion
The shared Solana governance service	Runs version 3.1.7, for which we found no public source, under a 5-of-7 council with no waiting period and no community veto.	Do not use it; a binding vote there would in practice be a council decision.
Legacy test-network tokens	Describe a superseded model. One token's supply exceeds the stated plan, its mint authority is live, and a single wallet can upgrade the program.	Set those authorities to none, or label the tokens as old test material.
Missing documents	Three architecture documents and the Symbiotic Licence page linked from the whitepaper do not load.	Republish them, or mark them withdrawn.

7. What can be borrowed

Each project below was inspected at a pinned commit (see References). The "how" column matters as much as the name.

Need	Project and version	How
Isolating helpers on Linux and macOS	@anthropic-ai/sandbox-runtime 0.0.81	Isolation only; never its key-masking mode
Signed, revocable add-ons	tuf-js 6.0.0	Behind a small wrapper; 107 of 108 conformance tests pass in its own CI
Permissions that expire and narrow	Biscuit (biscuit-wasm 0.6.0)	Mid-session withdrawal is still ours to build
Jobs that survive a crash	OpenWorkflow 0.11.0	Plus a small journal that prevents a repeated action
Evidence with selective disclosure	@sd-jwt 0.23.0	Behind a strict wrapper
One more helper and tool host	Goose v1.55.0	As one wrapped helper, never as the product's base
Local or cloud, by content	PII-Tracer (Perplexity)	As a detector only
The DAO's public record	Tessera v1.0.4 with witnesses	On one Linux server

Table 5. Reuse. Patterns worth reimplementing rather than adopting: Aegis's key broker and nanobrowser's action checks.

Disclosure. This research was carried out with Anthropic's Claude models. Anthropic also makes sandbox-runtime. We found a real flaw in its key-masking mode and recommend the library for isolation only.

8. Four notes for the maintainers

The community values openness, so these notes are shared in public. Each states what we saw, why it may matter, and what we suggest.

Note	What we saw	Why it may matter	What we suggest
Knowledge promotion broken since June	The promote step fails since commit 4098e28; no test calls it end to end.	Once fixed, the only gate would be a field the caller fills in, so a helper could promote its own output.	Fix it together with the approval helper, and add an end-to-end test.
Two licences on the Augmentor app	The Alpha vendors Augmentor 0.1.33 as MIT; on 23 September 2026 the original changed to "MIT with Augmentor Resale Restriction".	It is unclear which terms apply to the copy. This is a legal question, and we are not lawyers.	Decide which terms apply, take advice if needed, and state it in the licence notes.
A file that may hold members' details	One public community repository commits a database file whose table names suggest member records. We did not open the records.	If real, the details are public and remain in the repository history after deletion.	Check it; if real, remove it from history and use made-up sample data. The location is in the written DAO summary.
Missing documents on the DAO site	Three architecture documents and the Symbiotic Licence page do not load.	Readers cannot check the governance and licence claims.	Republish them, or mark them withdrawn.

9. Decisions for the maintainers

The research recommends; the people named decide. The full report lists twelve decisions; these are the ones that unlock the Now phase.

Decision	Recommendation	Who decides
Adopt the protected store, the approval helper and the key broker as new architecture decisions	Yes	Alpha maintainer
Harden the existing Alpha first, then extract the core along seams; keep a browser fork out of the next two cycles	Yes	Alpha maintainer
Declare DAO phase 1 off-chain, with no token until the audit, custody and test-network gate; restate the Q4 2026 mainnet target as conditional	Yes	DAO operating team and whitepaper authors
Set the legacy test-network authorities to none, or label the tokens	Set to none	Holder of the mint and upgrade keys
Label Windows helpers "unconfined" until Windows isolation is shown to work	Label now	Alpha maintainer
Hide provider presets that have no code behind them	Hide until implemented	Alpha maintainer
Run the three highest-ranked experiments in a throwaway virtual machine before the next planning cycle	Yes	Alpha maintainer

Table 6. Selected decisions. All twelve, with trade-offs and the evidence each needs, are in section 13 of the full report.

10. Limits, open questions and the experiments that would settle them

- **Windows isolation without administrator rights is unproven.** The one measurement we found shows breakage; we wrote down the test that would settle it.
- **Proof-of-personhood and collusion resistance** were not studied at code level. The DAO rules that depend on them remain policy.
- **No tool anywhere measures how much of a piece of work was done by a human and how much by AI.** The DAO's rules depend on that number. Until a measurement exists, treat it as a declared claim that a reviewer countersigns.
- **The Japanese and Korean ecosystems** were probed, not swept.

#	Experiment	What it settles
1	Windows isolation without administrator rights	Whether any helper can be confined on a standard Windows account
2	A hostile helper against the key broker	Whether redaction keeps a key from an echoing provider across encodings
3	tuf-js against the latest conformance suite, with the offline guard	Whether signed add-ons hold up, including offline root rotation
4	Withdrawing a delegated permission mid-session	Whether revocation takes effect within about a second
5	A consent-bounded attestation from the OS to the DAO	Whether evidence can flow to the DAO without exposing more than the person agreed to
6	Crash and restart with an uncertain side effect	Whether a job resumes without repeating an action
7	The browser gate against an injection corpus	Whether human-only actions resist crafted pages
8	Contribution fraud, appeal and a witnessed-ledger pilot	Whether the off-chain phase detects abuse and handles appeals

Table 7. Proposed experiments, ranked. Each verdict in this paper that depends on a test is conditional on it.

11. How to help

Five first tasks, each under two days of work and needing no design decision:

- correct the status pages;
- block the protected store's folder from AI helpers;
- require a password and a same-site check on the open bridge addresses;
- hide provider presets that have no code behind them;
- write the memory settings file atomically, so a crash cannot corrupt it.

The full report adds 25 issues written so they can be filed as they are, the eight experiments above, and a ranked list of the next ten engineering moves with a testable definition of done for each.

References

Project sources

ResonantOS/2.0.0-alpha, commit 578fbbc3c1c854b192318b3d2163b138fb45d8bd, branch dev, 18 October 2026; CI runs alpha-build 39097845387 and agent-control-live 39225094790 (both successful). Accessed 20 October 2026.

ResonantDAO whitepaper v0.6 (30 August 2026), Contribution Economy specification v2, membership portal. Accessed 20 October 2026. The three cited architecture documents and the Symbiotic Licence page returned "not found".

Solana devnet and mainnet records for the ResonantDAO test mints, program and upgrade authority; public RPC reads on 20 and 21 October 2026.

Inspected codebases (pinned commits)

anthropics/sandbox-runtime c40cf14 (v0.0.81).

theupdateframework/tuf-js a399ce8 (6.0.0); tuf-conformance v2.4.0 run 39558085285.

eclipse-biscuit/biscuit-rust 93832a8; biscuit-wasm 80cceed (npm 0.6.0).

openworkflowdev/openworkflow c82fbed (0.11.0).

openwallet-foundation-labs/identity-common-ts 42586ca (@sd-jwt 0.23.0).

aaif-goose/goose 9920efa (v1.55.0).

transparency-dev/tessera 012e9e0 (recommendation pins v1.0.4, 6bca8e8d).

getaegis/aegis f1321b3 (v1.0.5).

nanobrowser/nanobrowser f1e912d (v0.3.0).

Convira/convira-sandbox 9013c32 (no release).

dapr/durabletask-go a89450a (v0.15.1).

holepunchto/hypercore 9c9cc3d (11.39.0).

datalad/datalad 77de8d9 (1.7.1).

hypercerts-org/hypercerts-lexicon db1f41c (v1.5.1).

solana-foundation/rewards aa1cfd9 (audited) and 0b1bf17 (HEAD).

Mythic-Project/solana-program-library (governance) 00fa982; governance-program-library 1abc998; Squads-Protocol/v4 af94153.

Perplexity PII-Tracer, open-sourced 21 October 2026 (late addition; see the dossier in the full report).

Companion documents

ARTICLE.md: the full report covering both projects (14 sections), including 25 ready-to-file issues, eight experiments and twelve decisions.

APPENDIX.md: the evidence appendix: source index, coverage per platform and language, search method, verification failure rates, open questions and the 185-codebase longlist.

Plain-language summaries for ResonantOS and for ResonantDAO, each with its notes for the maintainers.

Research carried out with Anthropic's Claude models: Claude Fable 5.1 and Claude Opus 5.5 as leads, with Claude Sonnet 5.5 for discovery and citation checks. All findings were reviewed and released by the author.

Where to find everything

This paper cites ARTICLE.md, APPENDIX.md, and the plain-language summaries for ResonantOS and ResonantDAO by filename (previous page). All of it, along with every dossier, the threat model, the scoring worksheets, and the full session logs the research was produced from, is now published:

github.com/Goodgoan/resonantos-research — ResonantOS findings, architecture dossiers, OS-specific source material.

github.com/Goodgoan/resonantdao-research — ResonantDAO findings, governance dossiers, DAO-specific source material.

Both repositories carry ARTICLE.md and APPENDIX.md in full, so either one can be read on its own. Published 22 October 2026 under the same “findings to check, not verdicts” basis as the rest of this paper.